Phishing

SNAPPED PHISH-ING LINE

LAB WRITEUP

By :
Alexandro Achalma

Descripción: Analizar correos electrónicos y URL maliciosas, exponiendo una vasta campaña de phishing.

Dificultad: 🟢 Easy

18/09/2026

Snapped Phish-ing Line

Contexto

SwiftSpend Financial recibe una oleada de correos sospechosos reportados por empleados de distintos departamentos. Varios usuarios ya habían entregado sus credenciales y habían perdido acceso a sus cuentas.

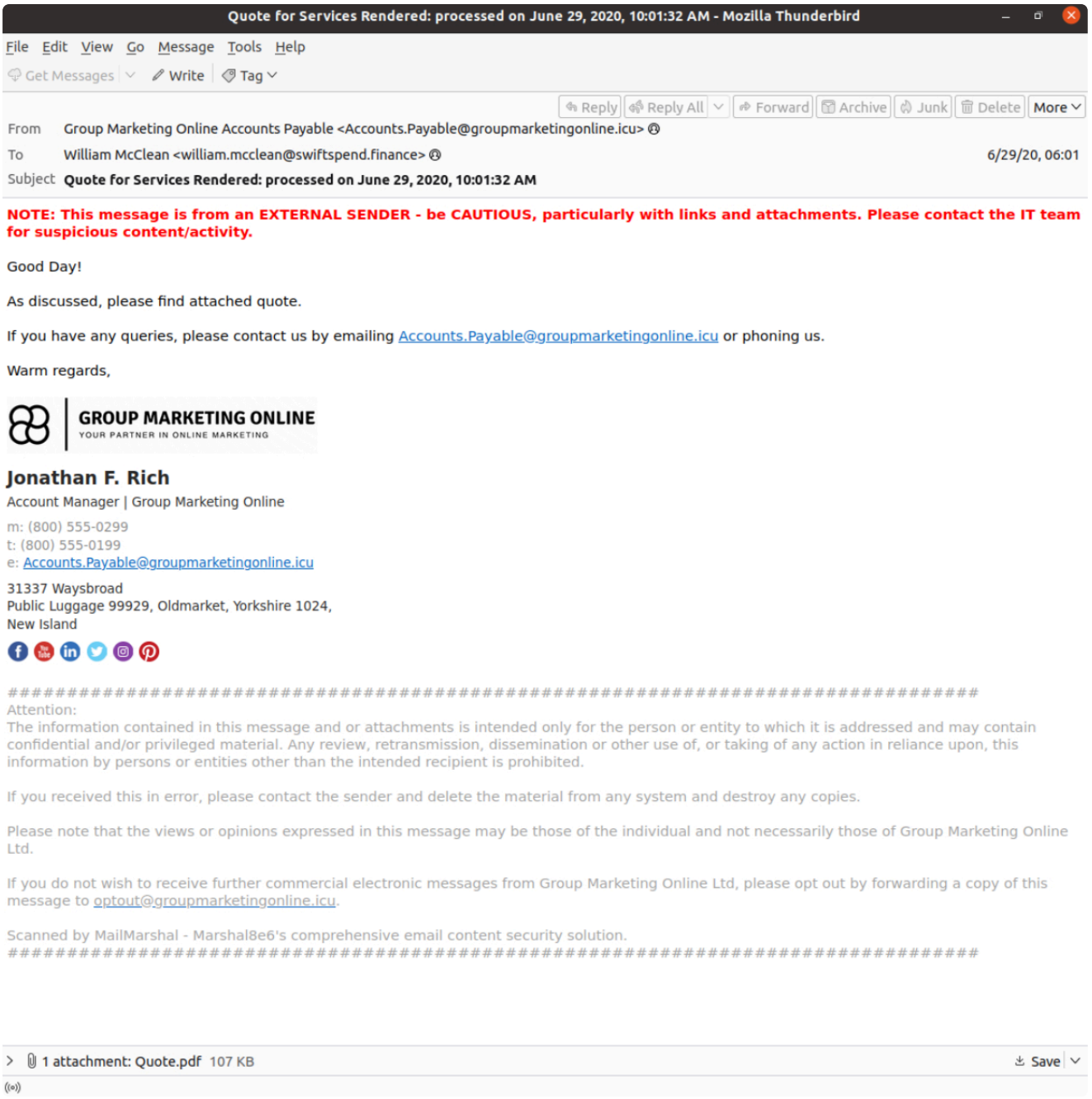
Objetivo

- Identificar los artefactos clave presentes en los correos de phishing
- Rastrear las URLs de redirección para comprender el flujo del ataque
- Recuperar y examinar el kit de phishing utilizado
- Usar herramientas de CTI para recopilar inteligencia sobre el adversario
- Analizar el kit para descubrir indicadores adicionales de compromiso

---

Fase 1 — Análisis del correo de phishing

La carpeta `phish-emails` del escritorio contiene varios correos dirigidos a distintos empleados. Al revisarlos, se identifica uno especialmente relevante: un mensaje con el asunto **"Quote for Services Rendered"** dirigido a **William McClean**.



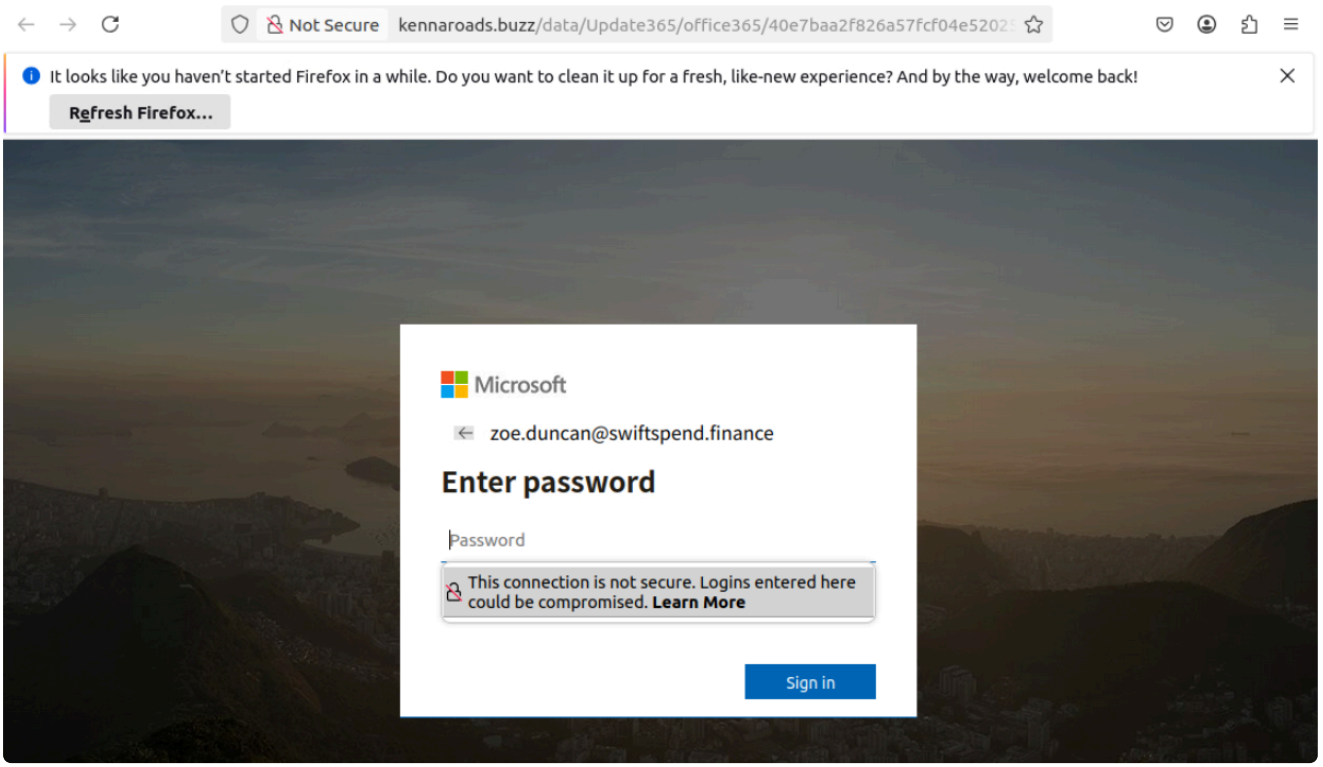
El correo proviene de una dirección que suplanta a una empresa de marketing:

> `Accounts.Payable@groupmarketingonline.icu`

El remitente se presenta como **Jonathan F. Rich**, Account Manager de *Group Marketing Online*, e incluye un adjunto llamado `Quote.pdf` de 107 KB. El correo lleva la advertencia del sistema de que proviene de un **remitente externo**, lo cual ya es una señal de alerta.

Fase 2 — Investigación del adjunto y la URL de redirección

El adjunto del correo dirigido a **Zoe Duncan** contiene una URL de redirección. Al inspeccionarlo, se identifica que el dominio raíz al que apunta es: `kennaroads.buzz`
Al abrir el adjunto en el navegador de la máquina virtual, se carga una página que suplanta el portal de inicio de sesión de **Microsoft**, pre-rellenando el campo de usuario con `zoe.duncan@swiftspend.finance` y solicitando la contraseña. El navegador mismo advierte que la conexión no es segura.



La URL completa visible en la barra del navegador revela la estructura del kit:

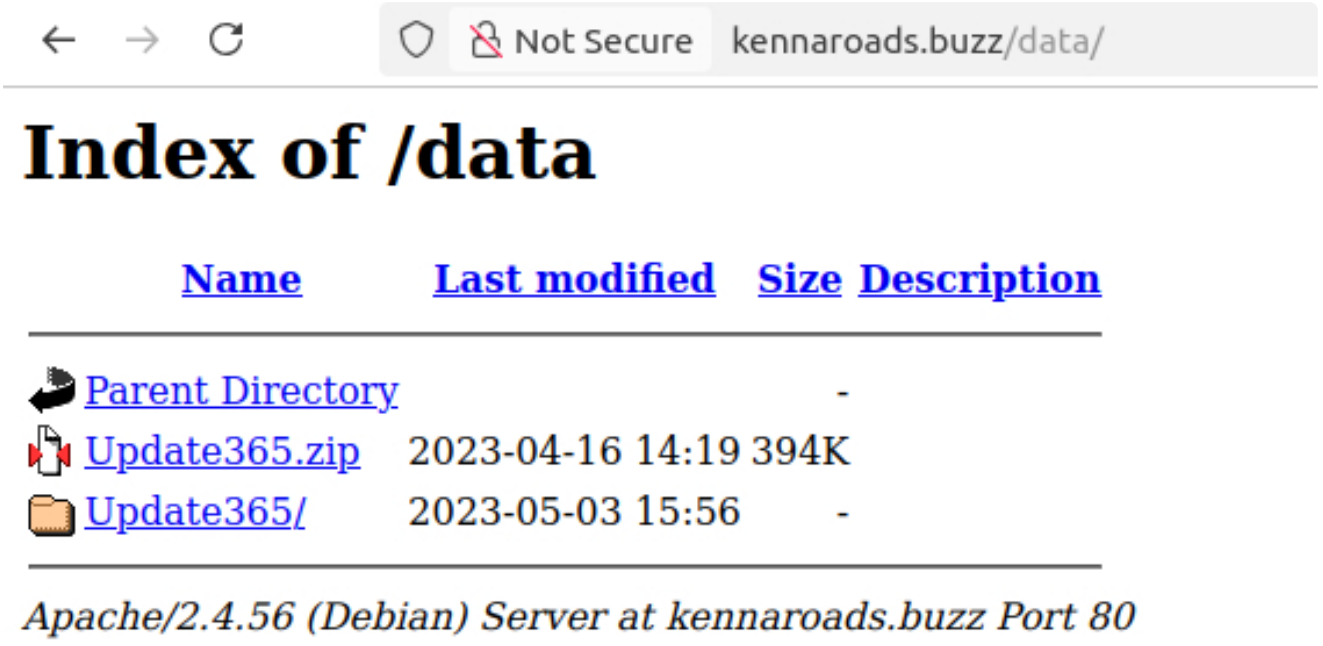
> `kennaroads.buzz/data/Update365/office365/40e7baa2f826a57fcf04e5202...`

Fase 3 — Descubrimiento del kit de phishing

Navegando al directorio `/data/` del servidor del atacante, se comprueba que el **directory listing está habilitado**, lo que expone el contenido del servidor sin autenticación:

> `kennaroads.buzz/data/`

El directorio expone un archivo de gran interés: `Update365.zip`



Se descarga el archivo y se evalua el hash con `sha256sum`

> `sha256sum Update365.zip`

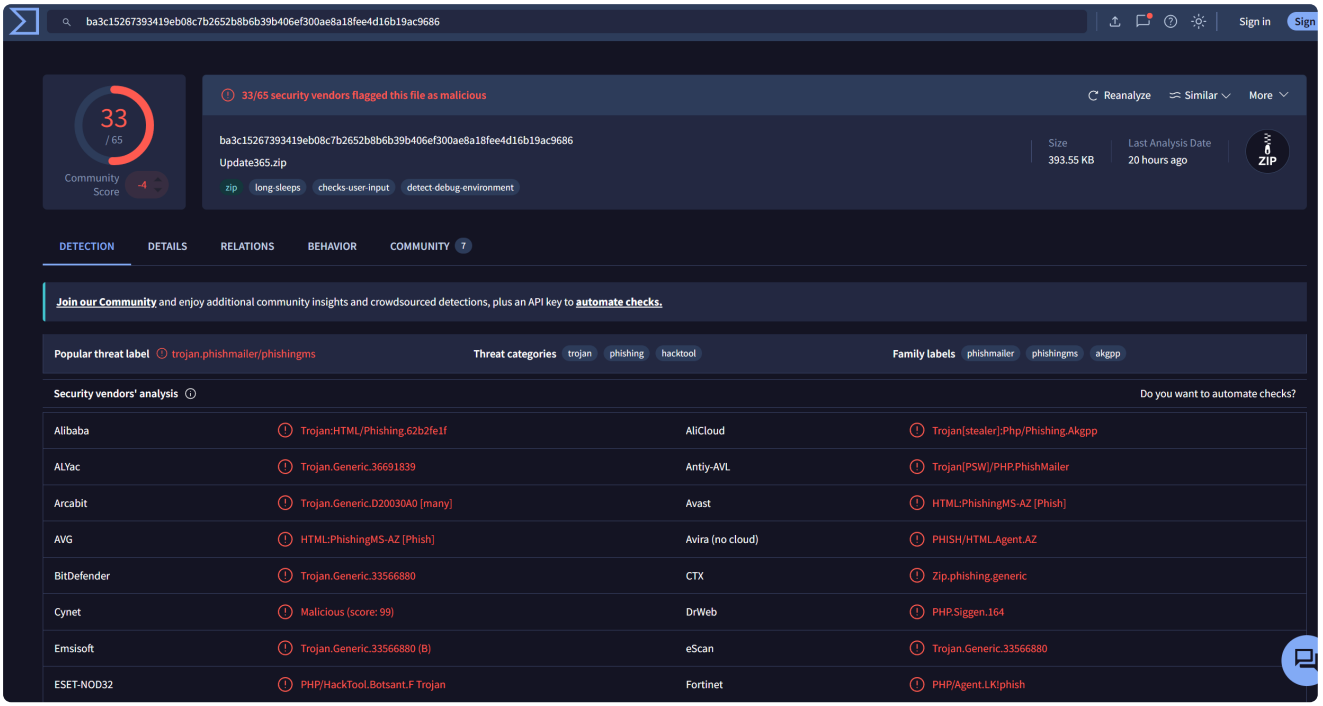
```
damianhall@ip-10-64-141-12:~$ ls
Desktop    Downloads  Pictures  Templates          Videos
Documents  Music      Public    thinclient_drives
damianhall@ip-10-64-141-12:~$ cd downloads
bash: cd: downloads: No such file or directory
damianhall@ip-10-64-141-12:~$ cd Downloads/
damianhall@ip-10-64-141-12:~/Downloads$ ls
Update365.zip
damianhall@ip-10-64-141-12:~/Downloads$ sha256sum Update365.zip
ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686  Update365.zip
damianhall@ip-10-64-141-12:~/Downloads$
```

> Hash: ba3c15267393419eb08c7b2652b8b6b39b406ef300ae8a18fee4d16b19ac9686

`sha256sum`**:** Utilidad de línea de comandos que calcula el hash SHA-256 de un archivo. Se usa en análisis forense para verificar la integridad de los archivos y poder buscarlos en bases de datos de inteligencia de amenazas como VirusTotal.

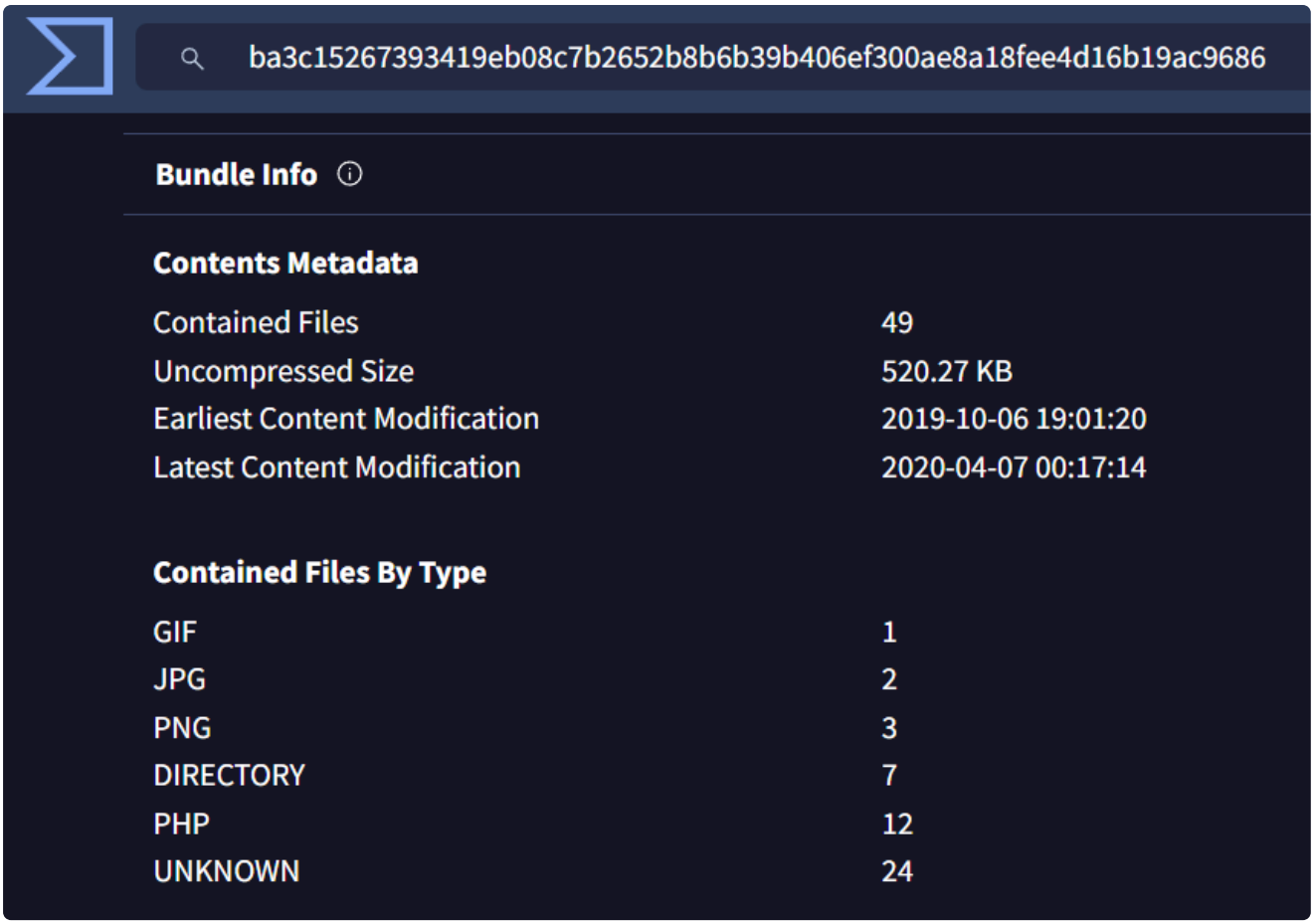
Fase 4 — Análisis de inteligencia en VirusTotal

El hash obtenido se busca en **VirusTotal**. Los resultados son contundentes:



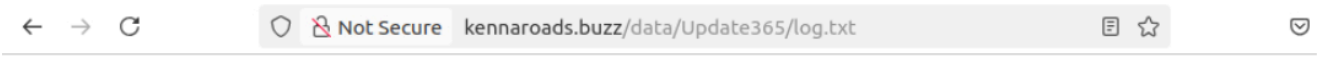
33 de 63 motores antivirus marcan el archivo como malicioso. Las categorías de amenaza asignadas son **phishing** y **Trojan**, con etiquetas de familia como `phishmailer`, `phishingms` y `akgpp`. Vendors como Alibaba, ALYac, Arcabit, BitDefender y Fortinet lo detectan con distintos nombres, pero todos coinciden en su naturaleza maliciosa.

En la pestaña **Details** de VirusTotal, la sección *Bundle Info* revela la composición interna del archivo, distribuyendose entre: 1 GIF, 2 JPG, 3 PNG, 7 directorios, **12 PHP** y 24 de tipo desconocido.



Fase 5 — Credenciales capturadas expuestas

El directorio `/data/Update365/` también expone un archivo de log con las credenciales robadas. Al acceder a `kennaroads.buzz/data/Update365/log.txt`, se puede leer el registro completo de víctimas:




```
---------+ Office365 Login  |+-------
Email : isaiah.puzon@gmail.com
Password : PhishMOMUKAMO123!
----------------------------------
Client IP: 158.62.17.197
User Agent : Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:109.0) Gecko/20100101 Firefox/112.0
Country : Philippines
Date: Mon Jun 29, 2020 10:00 am
--- http://www.geoiptool.com/?IP=158.62.17.197 ----
--+ Created BY Real Carder +---
---------+ Office365 Login  |+-------
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
----------------------------------
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
---------+ Office365 Login  |+-------
Email : zoe.duncan@swiftspend.finance
Password : Passw0rd1!
----------------------------------
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
---------+ Office365 Login  |+-------
Email : michael.ascot@swiftspend.finance
Password : Invoice2023!
----------------------------------
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
---------+ Office365 Login  |+-------
Email : derick.marshall@swiftspend.finance
Password : lol
----------------------------------
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
---------+ Office365 Login  |+-------
Email : michelle.chen@swiftspend.finance
Password : testing123
----------------------------------
Client IP: 64.62.197.80
User Agent : Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/60.0.3112.113 Safari/537.36
Country : United States
Date: Mon Jun 29, 2020 10:01 am
--- http://www.geoiptool.com/?IP=64.62.197.80 ----
--+ Created BY Real Carder +---
```

Entre las entradas se observan víctimas como `zoe.duncan@swiftspend.finance`, `derick.marshall@swiftspend.finance` y `michelle.chen@swiftspend.finance`. Sin embargo, el usuario `michael.ascot@swiftspend.finance` aparece registrado en más de una ocasión con la contraseña `Invoice2023!`, lo que indica que sus credenciales fueron capturadas múltiples veces.

Fase 6 — Análisis del kit de phishing

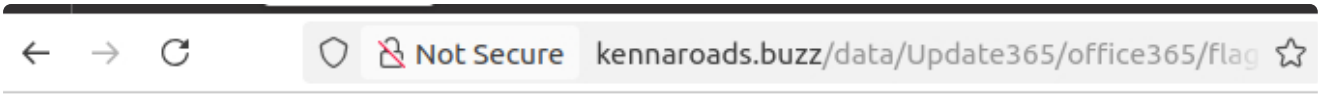
Una vez descargado y descomprimido `Update365.zip`, se localiza el archivo `submit.php`, responsable de procesar las credenciales robadas. Dentro del código se encuentra la dirección de correo a la que el atacante recibe los datos capturados:

> `m3npat@yandex.com`

Fase 7 — Recuperación de la flag

Navegando dentro de la URL del kit de phishing, se localiza el archivo `flag.txt`:

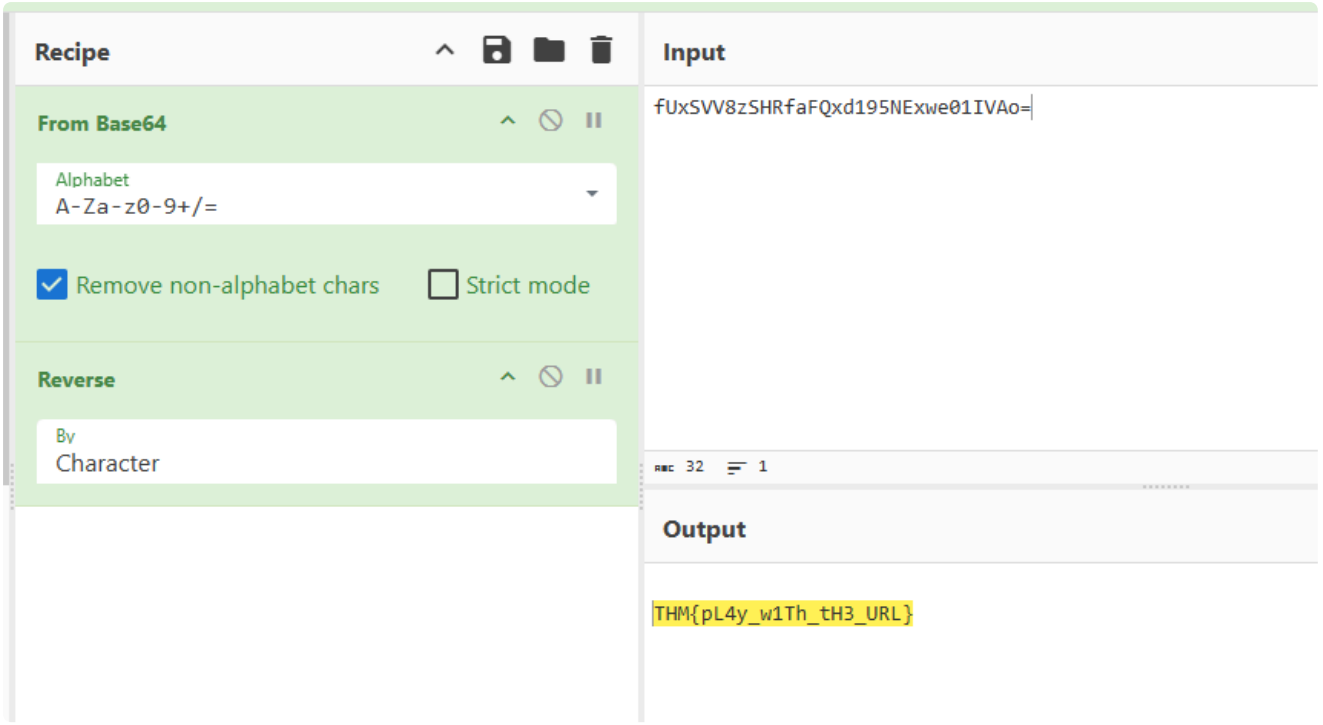
> `http://kennaroads.buzz/data/Update365/office365/flag.txt`




```
The secret is:
fUxSVV8zSHRfaFQxd195NExwe01IVAo=
```

THM{pL4y_w1Th_tH3_URL}

La cadena está codificada en **Base64**. Se decodifica usando **CyberChef** con la receta `From Base64` seguida de `Reverse`:



> Input: fUxSVV8zSHRfaFQxd195NExwe01IVAo=
> Output: THM{pL4y_w1Th_tH3_URL}

REFERENCIAS

- TryHackMe. Snapped Phish-ing Line. https://tryhackme.com/room/snappedphishingline
- VirusTotal. https://www.virustotal.com/gui/home/upload
- CyberChef — The Cyber Swiss Army Knife. https://gchq.github.io/CyberChef/
- MITRE ATT&CK. *T1566.001 — Phishing: Spearphishing Attachment*. https://attack.mitre.org/techniques/T1566/001/
- MITRE ATT&CK. *T1078 — Valid Accounts (Credential Harvesting)*. https://attack.mitre.org/techniques/T1078/